THE SECURITY OF A VLSI IMPLEMENTATION OF THE NEW AES AGAINST POWER AND TIMING ATTACKS

A thesis submitted to the University of Manchester
for the degree of Doctor of Philosophy
in the Faculty of Science and Engineering

2003

By
An Yu
Department of Computer Science

Contents

List of Tables

List of Figures

Abstract

In recent years, new cryptanalytical techniques have been invented namely power and timing analysis, which pose a serious threat to cryptographic devices such as smartcards. By analysing the power dissipation or timing of encryptions in these devices, secret information inside can be deduced. The weakness, however, is not in the encryption algorithms themselves, but in their implementations. Almost every hardware devices incorporating encryption algorithms are vulnerable to power and timing attacks. These attacks take significantly less time than a brute-force search and they leave no trace that the device has been tampered with.

Power and timing attacks are real threats to cryptographic hardware, which cannot be simply ignored. AES, as the new encryption standard, will soon be adopted by many organisations such as banks and governments. Thus it is important to assess vulnerability of hardware implementations of AES and to introduce new designs to foil such attacks. This research implemented the secure AES cipher in asynchronous circuits. An analysis shows that an AES implementation in a single-rail design style is vulnerable to a power attack. The weakness is corrected by a dual-rail implementation. Experimental results show that this implementation has a considerable improvement in resistance against power attacks.

Declaration

No portion of the work referred to in this thesis has been submitted in support of an application for another degree or qualification of this or any other university or other institution of learning.

Copyright

Acknowledgements

I would like to thank members of the AMULET group, especially Dr. Andrew Bardsley's support on various technical issues, comments on the first draft of this thesis and the help for designing a ROM.

I am also very grateful to the reviewers, my supervisor, Prof. David Brée (proof-reading), Dr. Steve Temple (proof-reading) and my adviser, Dr. Ning Zhang, who provided their valuable comments on this thesis. Also my thanks go to Dr. Luis Plana for sharing his view on the asynchronous circuits in terms of timing issues.

This research is sponsored by the Overseas Research Students Awards Scheme (ORS) and the Department of Computer Science. The support is greatly appreciated.

Finally, I would like to thank my wife and parents for years of continued support.

Chapter 1

Introduction

Cryptography is about code designing and code breaking. To keep secret information known only to the intended recipients, ciphers are designed which scramble the information into an unreadable form that can only be decrypted with the right key. As a secret is only shared within a small number of people, those who want to know the secret but don't have the key, try to break the code. This is how the game between code-designers and code-breakers started, and it has lead to advances in cryptology.

Ciphers have undergone many changes. The primitive ciphers, invented two thousand years ago, encode messages by simply substituting for each letter another in the ciphertext or by shuffling the letters to different positions. This is not a true encryption as these ciphers don't have keys; they are easy to break by letter frequency analysis. As a result, a more advanced type of cipher, the polyalphabetic cipher, was invented, which allowed one plaintext letter to be substituted by different ciphertext letters depending on the context. This cipher doesn't have keys either, and so the same plaintext always resulted in an identical ciphertext. Hence, the design of the cipher had to be kept secret. This problem was finally solved by the invention of keys in 1500s. Now two parties could share secrets using a common cipher key and they could also change keys as desired. The concepts of polyalphabeticity and the key are still at the heart of the design of modern ciphers.

The security strength of a modern cipher is usually referenced to the length of its cipher key. For instance, a cipher supporting 128-bit keys means that there are 2^{128} possible keys to choose from. The combinations are enormous; if one were to try to decrypt a message by searching for the key that had been used, it

would take millions and millions of years even using today's computers. However the assumption here is that there are no shortcuts which could find a key using less effort than trying every possible key.

Thanks to advanced cryptanalysis techniques, such as differential and linear cryptanalysis, today we have a number of ciphers (e.g. 3DES, Rijndael, Serpent and Twofish, etc) that are regarded as strong ciphers. They have undergone years of extensive cryptanalysis by cipher experts and the cryptography community. These ciphers have no known hidden weakness or shortcuts and are considered to be computationally infeasible to break. In other words, the most efficient way to find an unknown key is a brute-force attack: searching every possible key.

With these trustworthy ciphers, are we safe from security breaches? The answer is 'no'. Although a cipher itself can be secure, a security product that uses such a cipher doesn't inherit the strength automatically. For instance, a house front door installed with the world's most secure lock won't necessarily prevent a break in, as there may well be other weakness in the house that an intruder can exploit, e.g. the windows. The house will only be as secure as the lock if there are no other weaknesses to be found.

In computer security, many security breaches fall into this type of example. For instance, some Unix systems use a modified DES cipher for user access authentication. The maximum length of a password is 8 characters, equivalent to 64 bits. The effective bits are only 56, as every eighth bit is ignored by the DES algorithm, that is 2^{56} possible combinations to choose from. However, certain passwords are weak (e.g. any word that can be found in a dictionary is considered weak, or the length of a password is short); some of them can be cracked within seconds by a dictionary attack. Even where strong passwords are used, security breaches can still happen. For example, a user runs the telnet program to access a remote computer, the password is transmitted in cleartext through the network as he logs in, so it can be captured by an adversary in the middle of the communication. There are many more such examples.

Similarly, cryptographic devices in hardware have similar problems. The reason for implementing cryptographic algorithms in hardware is that such devices are fast, reliable and difficult to duplicate. But more importantly, because of the difficulty in reverse engineering, the secret can be well hidden and protected. However no hardware is tamper-proof. Many techniques have been developed

that can safely depackage a silicon chip. The layout of a chip can then be reconstructed, using tools such as optical microscopes to produce high resolution photographs of the chip surface, and data, address bus lines, ROM, RAM, EEPROM, ALU, etc. identified. EEPROM (or recently Flash memory), where the secret is usually stored, can be read out using microprobing to observe the entire bus and to record the values in memory as they are accessed [35]; very often the built in sense amplifiers of the memories have to be used. Consequently, the secret information (e.g. master keys) is revealed. Depackaging and microprobing are not the only method that can compromise a chip's security. It inevitably leaves tamper evidence behind and it requires substantial skill and equipment in order to perform an attack. What's worrying are the techniques invented a few years ago, namely power and timing analysis. These cryptanalytic techniques study the behaviour of cryptographic devices through their execution time, power dissipation or electromagnetic emission, and then deduce the secret information. These types of attacks are difficult to detect because they don't involve tampering. Smartcards are particularly at risk, because they cannot be run in a monitored environment. A legitimate smartcard user can be an attacker, who can safely perform the attacks without being noticed by the card issuer. An even more worrying concern is that an attack can sometimes be undertaken very quickly and even without the owner of the card realising that it has happened. For example, when you are paying for goods or services in a shop, your credit card is inserted into a smartcard reader for processing. While the smartcard reader might look perfectly normal, it could actually be fitted with measuring devices which secretly make a series of measurements of the power consumed by your card; this data can be used to determine the secret keys inside the smartcard. The power measurement is done instantly, adding virtually nothing to the processing time you expected the normal transaction would take.

A power attack is surprisingly easy to perform. The equipment needed usually involves a data acquisition board (costing a few hundred pounds) or a digital oscilloscope as well as a PC. To probe the secret key in a device, an attacker needs to collect samples of instantaneous power dissipation as the target device is executing cryptographic operations. A small resistor is inserted in series with the power or ground input and the current is computed by dividing the voltage difference across the resistor by its resistance. When enough power samples are obtained, the attacker can then apply the power analysis technique to relate the

current to the internal state of the cipher, and very often, secret information, usually the cipher keys can be deduced. The number of power samples needed in an attack depends on the implementation of the cipher, which can vary from thousands (e.g. DES) to even a few tens of samples (e.g. Twofish) [16]. The power attack is a practical technique, which uses far fewer attempts than a brute-force attack. A timing attack is similar; it measures the time that a particular operation takes in a cipher, and relates the timing to the data that was processed. Consequently, cipher keys can be computed.

Power and timing attacks are real threats to cryptographic hardware, which cannot be simply ignored. In response to this problem, new designs are required to foil these attacks. This research aims to provide such a design. The cipher that was chosen was Rijndael, the Advanced Encryption Standard (AES). AES is a new encryption standard set by the US government to replace the ageing standard, Data Encryption Standard (DES), due to its 56-key being too short to prevent a brute-force attack. AES, however, uses 128-bit keys, which means that it would take millions and millions years to search for an unknown key using the computer power today. AES is likely to remain secure for some time (until a much more powerful computer is invented, e.g. Quantum computers). It is expected that AES will soon be accepted by governments, banks and many other organisations. As this algorithm is still quite new, there hasn't yet been much research based on power and timing analysis of hardware implementations of AES [10, 19, 16, 41]. This research is to build an AES cryptosystem in hardware, so that its vulnerability can be assessed and countermeasures can be put into place.

The AES cryptosystem I will be building is in asynchronous circuits, which is different from the usual, synchronous, circuit design style, where a global clock governs the entire circuit operation. The aim of this research is to verify whether or not an asynchronous AES implementation can achieve better security from the point of view of power and timing attacks. The asynchronous design style is chosen, because of a number of security advantages:

- Synchronous circuits are vulnerable to clock glitch attacks [4, 35]. Asynchronous circuit are clock-less, they are much less sensitive to this type of attack [44].
- Asynchronous circuits could reduce power consumption and electromagnetic emission, and so data-dependent information is likely to be reduced. [26, 7, 39, 50].

- Asynchronous dual-rail design style could reduce data-dependent power consumption by balancing the hamming weight of data. In the same way that data-dependent electromagnetic information could also be reduced [50].
- An extra benefit of the asynchronous dual-rail design style is that the circuit could be less sensitive to fault induction attacks [44, 65]. This benefit comes virtually free.

The thesis is in two parts: the first part introduces the necessary background information, and the second part presents the details of the experiments that have been done in the research. Chapter 1 (being this chapter) begins with a brief introduction of the security problem in the application of cryptography. In particular, hardware that implements encryption algorithms is vulnerable from implementation attacks even though the algorithm itself is computationally secure. Chapter 2 reviews the evolution of ancient cryptography and introduces modern cryptography, including the design of block ciphers and their modes of operation. The de-facto encryption standard DES, a block cipher is also examined in detail. Chapter 3 illustrates the AES algorithm that was implemented in hardware. Chapter 4 introduces two design styles of asynchronous circuits, which were used in my implementations. Chapter 5 describes the common threats to cryptographic hardware and how attacks can be performed.

Chapter 6 presents a single-rail AES implementation, from the design of encryption core to the ROM and RAM. Chapter 7 shows the results of the design from the point of view of power and timing attacks. Chapter 8 presents a dual-rail AES circuit, which addressed the security weakness found in the single-rail implementation. Chapter 9, presents the evaluation of the dual-rail version. Chapter 10 is the conclusion: hardware devices incorporating the AES need to be implemented in dual-rail.

1.1 Publications

The paper below has been submitted for publication:

- A Clock-less Implementation of the Advanced Encryption Standard Resistant to Power and Timing Attacks (Asiacrypt 2003)

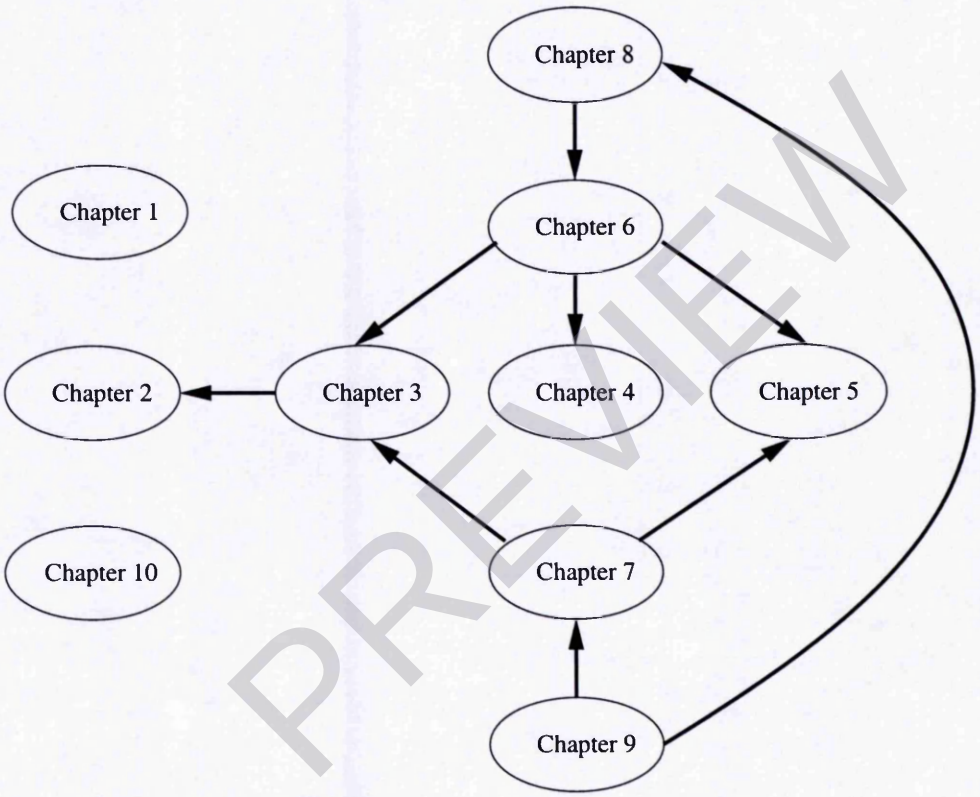

Figure 1.1: The dependency map of chapters

Chapter 2

Cryptography

This chapter reviews ancient cryptography (Section 2.1) and introduces modern cryptography (Section 2.2). The common modes of operation of a block cipher are described (Section 2.3). The de-facto encryption standard DES, a block cipher, is examined in detail (Section 2.4).

2.1 Cryptography History

Cryptography is the science of applying mathematics to encrypt and decrypt data. Cryptography enables sensitive information to be stored or transmitted across insecure communication channels (e.g. the Internet), so that the information cannot be read by anyone except the intended recipient.

Cryptography has a fascinating history. The first documented written cryptography was found about 4,000 years ago [31] . An Egyptian scribe used non-standard hieroglyphs in an inscription, found in the main chamber of the tomb of the nobleman Khnumhotep II. His inscription was not a system of secret writing as the modern world knows it. It only uses some unusual hieroglyphic symbols here and there in place of the more ordinary ones. The intention was not to make it hard to read the text, rather, it was to impart a dignity and authority to it. The inscription incorporated one of the essential elements of cryptography: a deliberate transformation of the writing.

About 50-60BC, the Roman emperor, Julius Caesar [31] used a simple substitution with the normal alphabet in government communications. This is a *Monoalphabetic Substitution Cipher*, which is merely shifting the letters a fixed

amount. Below is an example showing the ciphertext letters resulting from shifting the plaintext letters three times.

plaintext	a	b	c	d	e	f	g	h	i
ciphertext	D	E	F	G	H	I	J	K	L

In 1412, Shihāb Qalqashandi, an Egyptian, completed an enormous 14-volume encyclopaedia, which included a section on cryptology. The section named "*Concerning the concealment of secret messages within letters*". It consists of two parts, one deals with symbolic actions and allusions, the other with invisible inks and cryptology [31]. Qalqashandi summarised a number of cipher systems, such as shifting letters a fixed amount, writing words backwards, reversing alternate letters of the words of a message, using figures to substitute for letters, etc. It is the first time in cryptography that both transposition (shifting letters in a message to different positions) and substitution ciphers were introduced.

A monoalphabetic substitution cipher, however, is trivial to break because letters in a plaintext have a different frequency. Statistics shows that the letter 'e' appears the most in a message written in English, and then the letter 't', 'n', and so on. The letter frequency remains unchanged in the corresponding ciphertext due to the one to one relation between a plaintext letter and a ciphertext letter. Thus, the most frequent letter occurring in a ciphertext may well be the plaintext letter 'e' (or 't' if not). The weakness of monoalphabetic substitution ciphers was realised by Aeon Battista Alberti and led him to invent the first *polyalphabetic substitution cipher* in 1466 (this type of cipher was apparently not broken until the 1800's). In polyalphabetic substitution, ciphers as the name suggests, a plaintext letter are replaced by different ciphertext letters. The cipher works like a Caesar cipher using variable shifts. For instance, if one is to encrypt a message, one may choose to encrypt the first three words in a message with a 3-letter Caesar shift, and the following three words with a 4-letter shift and so on. In this cipher, the relationship between a plaintext letter and the corresponding ciphertext letter is variable. This cipher significantly increased the difficulty of code breaking. The invention of the polyalphabetic substitution cipher was a great leap forward in cryptography, as a consequence Alberti is often referred to as the Father of Western Cryptology.

Cryptography took another step forward in 1518, when Johannes Trithemius wrote his first printed book on cryptology. The book contains his contributions to polyalphabeticity. For the first time in cryptology, the square table appeared,

which is the elemental form of polyalphabetic substitution. Trithemius' square table (its first and last few rows) can be seen in Table 2.1:

plaintext	a	b	c	d	e	f	g	h	i	k	l	m	n	o	p	q	r	s	t	u	x	y	z	w
1	A	B	C	D	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	U	X	Y	Z	W
2	B	C	D	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	U	X	Y	Z	W	A
3	C	D	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	U	X	Y	Z	W	A	B
4	D	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	U	X	Y	Z	W	A	B	C
5	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	U	X	Y	Z	W	A	B	C	D
6	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	U	X	Y	Z	W	A	B	C	D	E
⋮																								
23	Z	W	A	B	C	D	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	U	X	Y
24	W	A	B	C	D	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	U	X	Y	Z

Table 2.1: The Trithemius square table

The columns are chosen by the plaintext letters and the rows by the sequential position of the letter in the plaintext.

The rule is that, the first letter is encrypted with the first alphabet in the first row, the second letter is encrypted with the second alphabet in the second row and so on. So a plaintext 'attack' is 'auxdgp' in ciphertext. By shifting alphabets for each letter, the letter patterns such as double letters are concealed. The advantage of this cipher over Alberti's is that a new alphabet is brought into play with each letter, whereas in Alberti's cipher, alphabets are only shifted after a few words, therefore, the patterns of repeated letters can still be found. Trithemius also introduced regular alphabet changes as part of the enciphering algorithm. The Trithemius square was a great influence in cryptology.

In 1553, Giovan Batista Belaso advanced the polyalphabetic cryptology another level. He introduced the concept of a key, which he called a *countersign* [31]. The key may consist of some words and the words may be repeated as many times as desired. Supposing our key is 'HELLO' and the plaintext is 'a secret message'. To encrypt this plaintext, we shall put them on paper in this manner:

plaintext	a	s	e	c	r	e	t	m	e	s	s	a	g	e
key	H	E	L	L	O	H	E	L	L	O	H	E	L	L
ciphertext	H	Y	P	N	R	M	Z	Y	P	G	A	A	R	P

The keyletter that is paired with a given plaintext letter indicates the alphabet of the square table (see Table 2.1) that is to be used to encipher that plaintext letter. Thus, the plaintext is encrypted to 'H YPNRMZ YPGAARP'. This system

permits great flexibility. A message is no longer encrypted using a fixed order of standard cipher alphabets, but the order depends on the key being chosen. His design is the standard polyalphabetic cipher operation misnamed *Vigenère* by most writers to this day.

A famous book *De Furtivis Literarum Notis* was published by Giovanni Battista Porta in 1563 [31]. The book covers ancient ciphers, modern ciphers, cryptanalysis and a list of linguistic peculiarities. He classified ciphers as transposition, substitution and symbol substitution (letters were substituted by strange symbols). He also suggested the use of synonyms and misspellings to confuse the cryptanalysts. He appeared to be the first person in cryptology to use the idea of substitution of two letters by a single symbol.

In 1585, a book about ciphers, *Traicte des Cometes*, written by Blaise de Vigenère, introduced the first authentic plaintext and ciphertext autokey system. The autokey system used a Trithemius-like square table, a single letter (the first letter of the key) is known to both encipherer and decipherer; with it the decipherer can decrypt the first ciphertext letter and so get a start on his work. With this, he gets the first plaintext letter, then he uses this as the key to decrypt the second ciphertext letter, uses that plaintext letter as the key to decrypt the third ciphertext letter, and so on. The cipher now universally called the Vigenère, employs only standard alphabets and a short repeating keyword. Below is an example:

plaintext	a	t	o	p	s	e	c	r	e	t
key	T	A	T	O	P	S	E	C	R	E
ciphertext	X	I	A	H	T	V	U	S	G	I

In 1863, a book *Die Geheimschriften und die Dechiffrir-kunst*, written by Friedrich W. Kasiski, gave the first general solution of a polyalphabetic cipher with a repeating keyphrase, thus marking the end of several hundred years of strength for the polyalphabetic ciphers. The impressive 95-page volume of cryptanalysis has made an incredible revolution in cryptology, but unfortunately it seems to have received little notice at that time.

A theory of cryptology, *The Index of Coincidence* [31], was created by William Frederick Friedman in 1915. He introduced a statistical technique, which could discover the coincidences in cryptograms and eventually solve them. This technique has had a great influence in the modern cryptanalysis, opening the door